```
┌──(kali㉿kali)-[/media/sf_hafta3_kali_eki]
└─$ python3 gorev1_pki_uret.py 212923045
PKI uretiliyor (pki/):
  yazildi: pki/ca.crt
  yazildi: pki/ca.key
  yazildi: pki/lab.crt
  yazildi: pki/lab.key

Bitti. Kontrol:
  openssl x509 -in pki/lab.crt -noout -subject -issuer -ext subjectAltName
  Beklenen Issuer: Siber Güvenlik Ders Kök CA - 212923045

┌──(kali㉿kali)-[/media/sf_hafta3_kali_eki]
└─$ ls
BENIOKU_KALI.md     gorev2_https_sunucu.py  zayif_sunucu.py
gorev1_pki_uret.py  pki

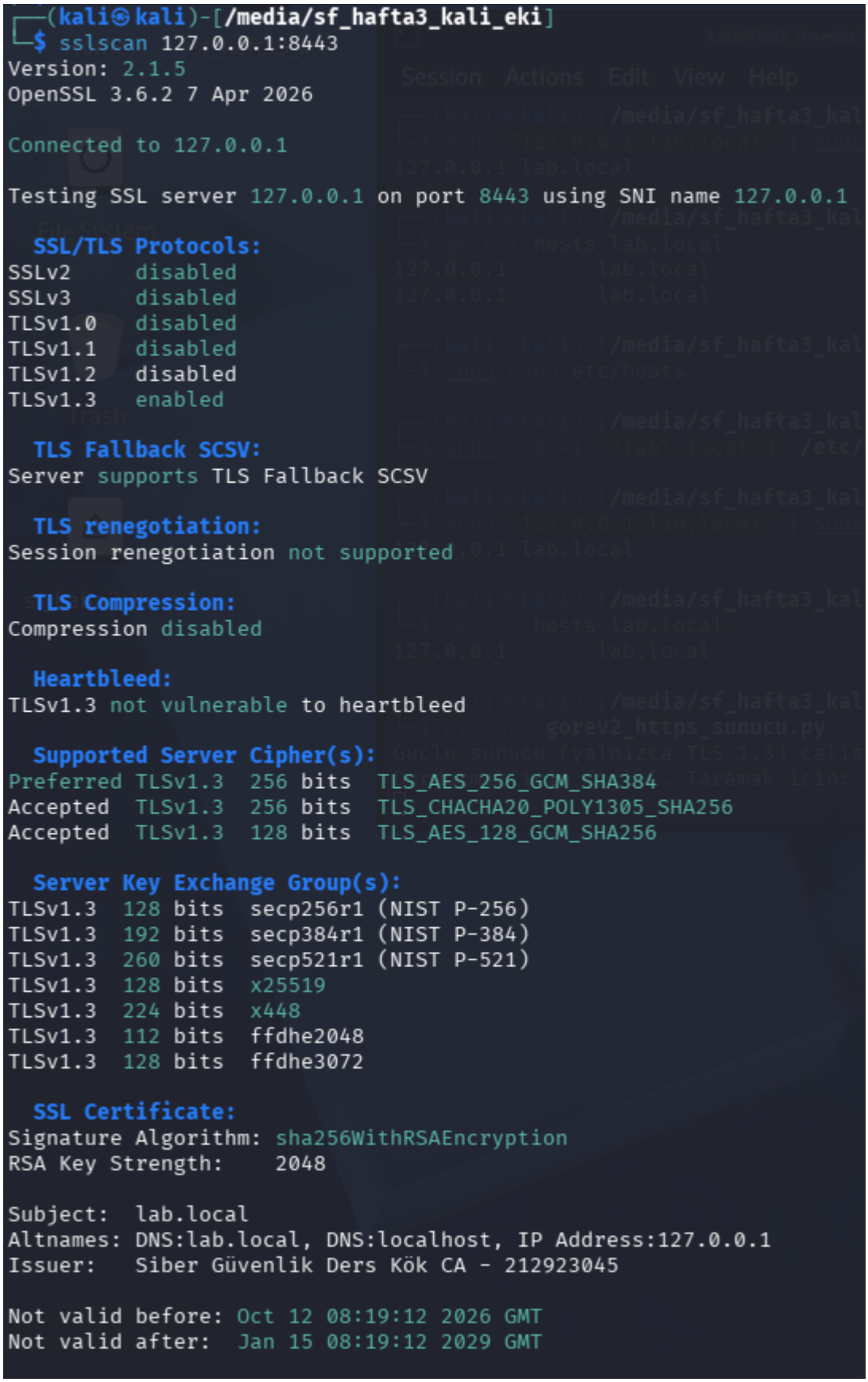
┌──(kali㉿kali)-[/media/sf_hafta3_kali_eki]
└─$ ls pki/
ca.crt  ca.key  lab.crt  lab.key
```

```
┌──(kali㉿kali)-[/media/sf_hafta3_kali_eki]
└─$ echo "127.0.0.1 lab.local" | sudo tee -a /etc/hosts
127.0.0.1 lab.local

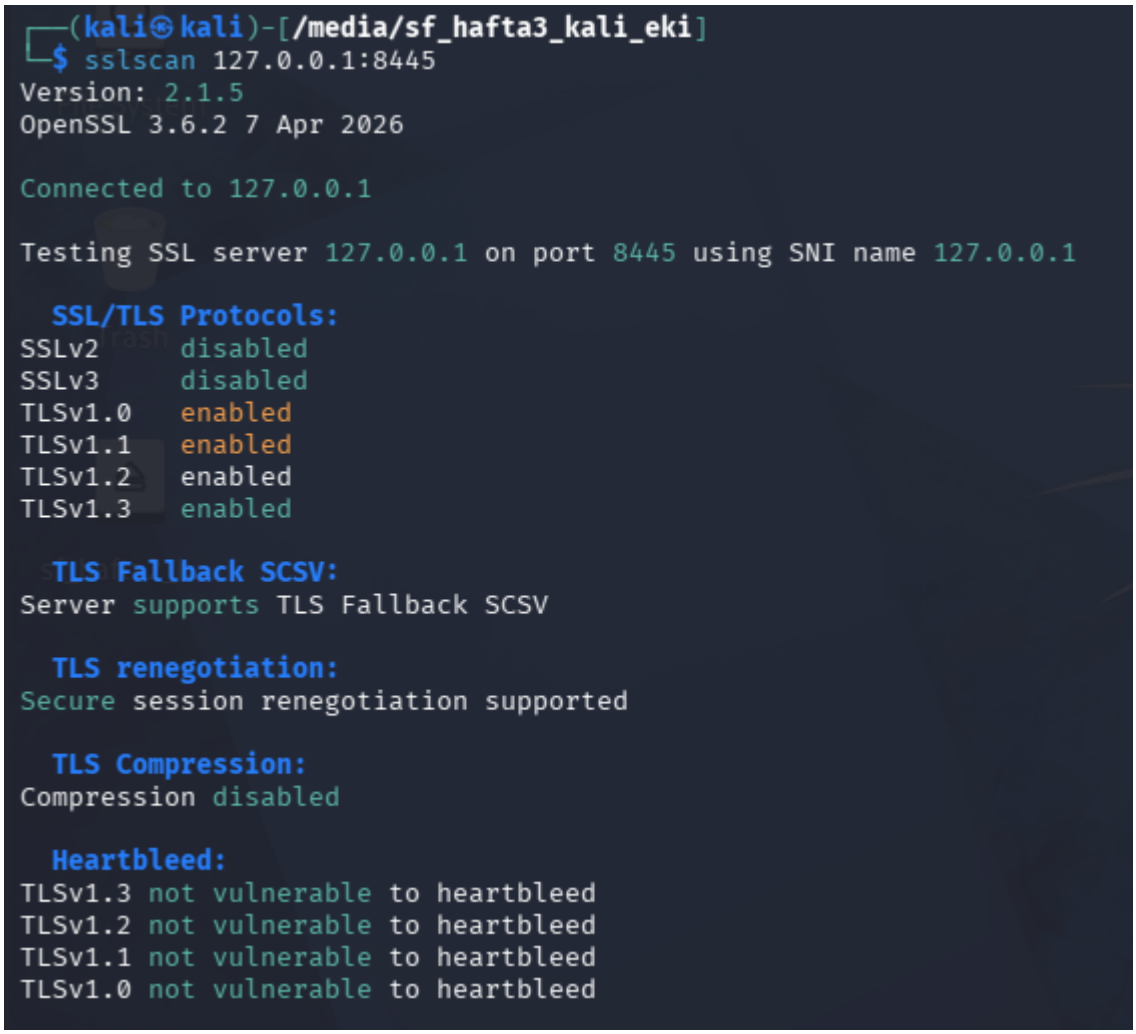
┌──(kali㉿kali)-[/media/sf_hafta3_kali_eki]
└─$ getent hosts lab.local
127.0.0.1       lab.local
```

```
┌──(kali㉿kali)-[/media/sf_hafta3_kali_eki]
└─$ python3 gorev2_https_sunucu.py
Guclu sunucu (yalnizca TLS 1.3) calisiyor: https://127.0.0.1:8443
Durdurmak icin Ctrl+C. Taramak icin:  sslscan 127.0.0.1:8443
```

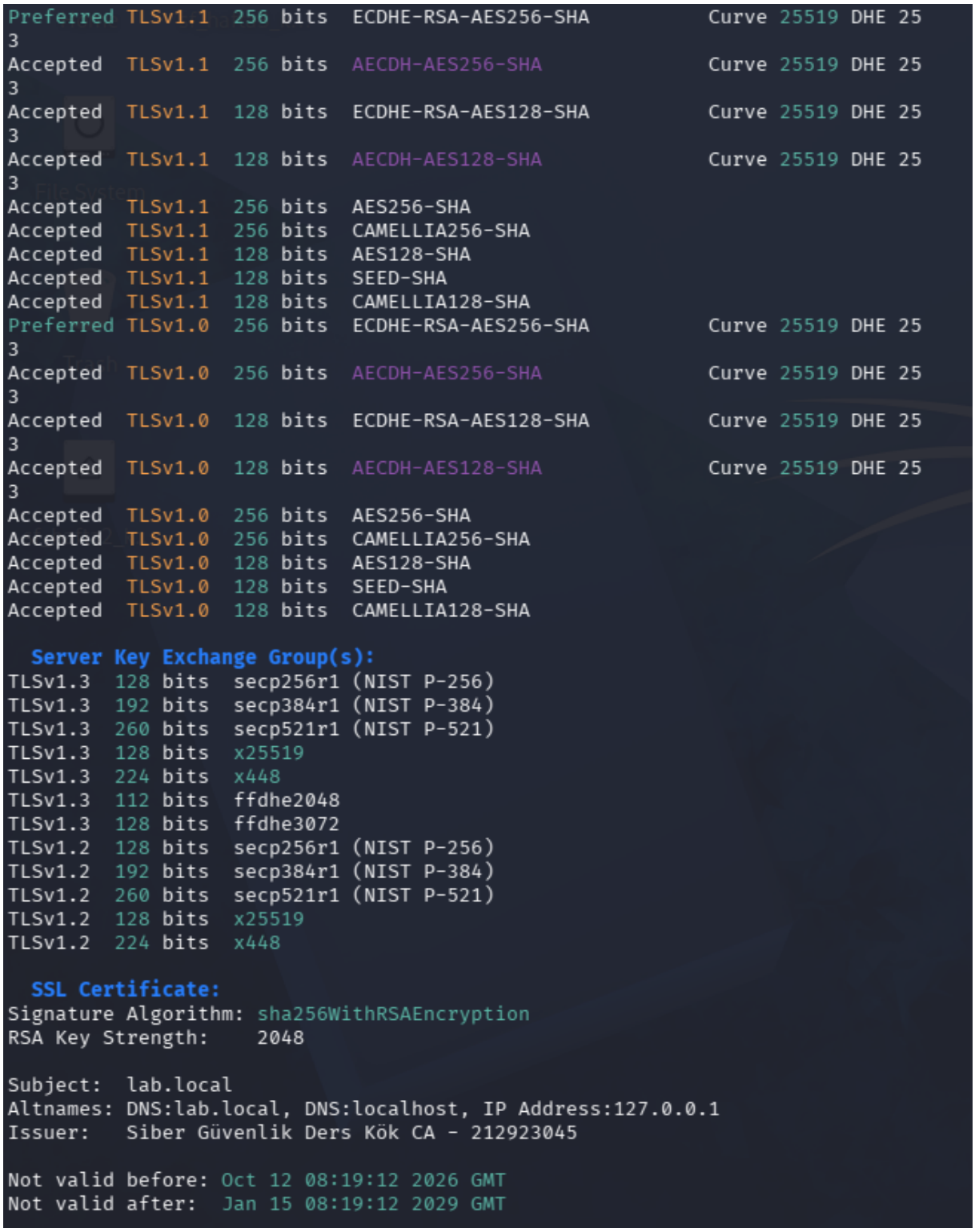
GÜÇLÜ SUNUCU



ZAYIF SUNUCU

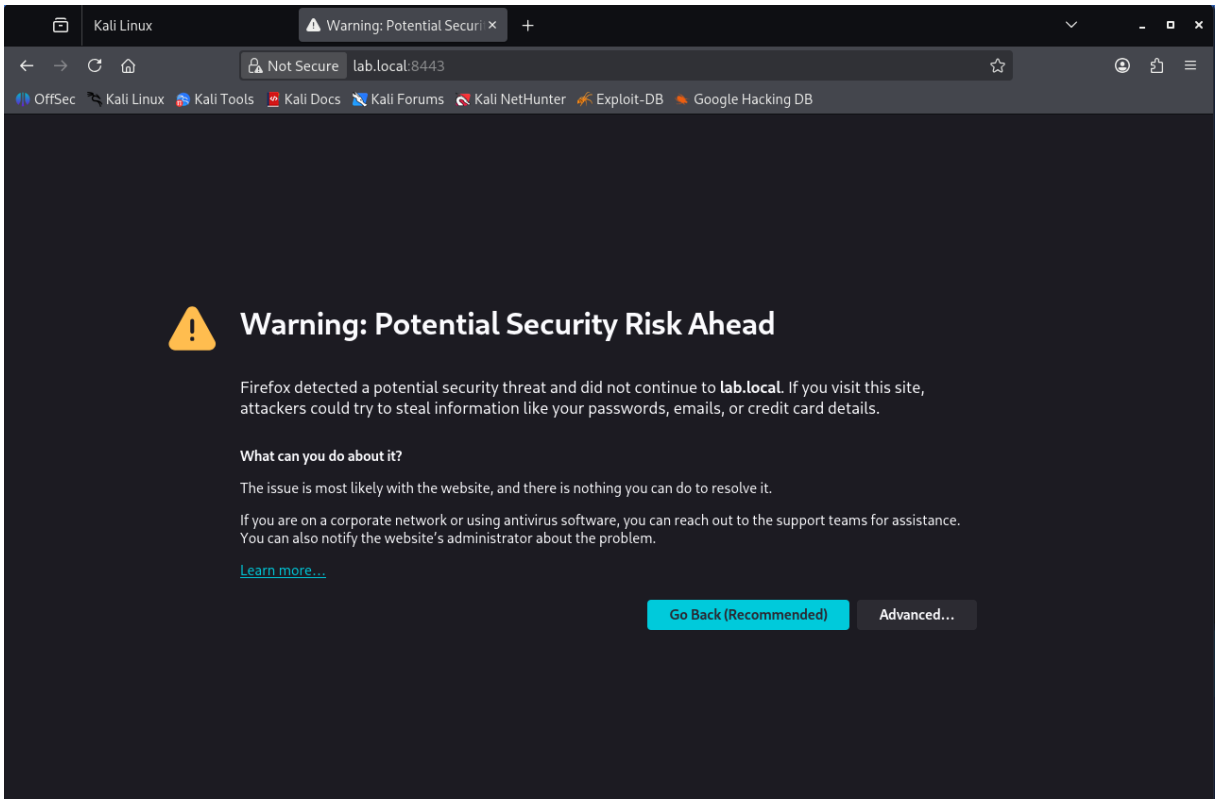


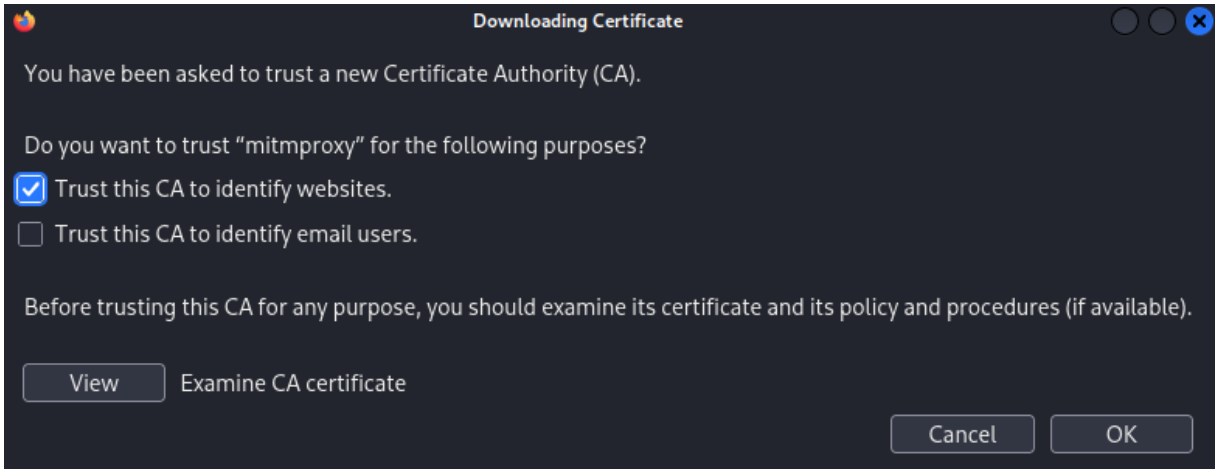
```
  Supported Server Cipher(s):
Preferred TLSv1.3  256 bits  TLS_AES_256_GCM_SHA384
Accepted  TLSv1.3  256 bits  TLS_CHACHA20_POLY1305_SHA256
Accepted  TLSv1.3  128 bits  TLS_AES_128_GCM_SHA256
Preferred TLSv1.2  256 bits  ECDHE-RSA-AES256-GCM-SHA384   Curve 25519 DHE 25
3
Accepted  TLSv1.2  256 bits  ECDHE-RSA-CHACHA20-POLY1305   Curve 25519 DHE 25
3
Accepted  TLSv1.2  256 bits  ECDHE-ARIA256-GCM-SHA384      Curve 25519 DHE 25
3
Accepted  TLSv1.2  128 bits  ECDHE-RSA-AES128-GCM-SHA256   Curve 25519 DHE 25
3
Accepted  TLSv1.2  128 bits  ECDHE-ARIA128-GCM-SHA256      Curve 25519 DHE 25
3
Accepted  TLSv1.2  256 bits  ECDHE-RSA-AES256-SHA384       Curve 25519 DHE 25
3
Accepted  TLSv1.2  256 bits  ECDHE-RSA-CAMELLIA256-SHA384  Curve 25519 DHE 25
3
Accepted  TLSv1.2  128 bits  ECDHE-RSA-AES128-SHA256       Curve 25519 DHE 25
3
Accepted  TLSv1.2  128 bits  ECDHE-RSA-CAMELLIA128-SHA256  Curve 25519 DHE 25
3
Accepted  TLSv1.2  256 bits  ECDHE-RSA-AES256-SHA          Curve 25519 DHE 25
3
Accepted  TLSv1.2  256 bits  AECDH-AES256-SHA              Curve 25519 DHE 25
3
Accepted  TLSv1.2  128 bits  ECDHE-RSA-AES128-SHA          Curve 25519 DHE 25
3
Accepted  TLSv1.2  128 bits  AECDH-AES128-SHA              Curve 25519 DHE 25
3
Accepted  TLSv1.2  256 bits  AES256-GCM-SHA384
Accepted  TLSv1.2  256 bits  AES256-CCM
Accepted  TLSv1.2  256 bits  ARIA256-GCM-SHA384
Accepted  TLSv1.2  128 bits  AES128-GCM-SHA256
Accepted  TLSv1.2  128 bits  AES128-CCM
Accepted  TLSv1.2  128 bits  ARIA128-GCM-SHA256
Accepted  TLSv1.2  64 bits   AES256-CCM8
Accepted  TLSv1.2  64 bits   AES128-CCM8
Accepted  TLSv1.2  256 bits  AES256-SHA256
Accepted  TLSv1.2  256 bits  CAMELLIA256-SHA256
Accepted  TLSv1.2  128 bits  AES128-SHA256
Accepted  TLSv1.2  128 bits  CAMELLIA128-SHA256
Accepted  TLSv1.2  256 bits  AES256-SHA
Accepted  TLSv1.2  256 bits  CAMELLIA256-SHA
Accepted  TLSv1.2  128 bits  AES128-SHA
Accepted  TLSv1.2  128 bits  SEED-SHA
Accepted  TLSv1.2  128 bits  CAMELLIA128-SHA
```

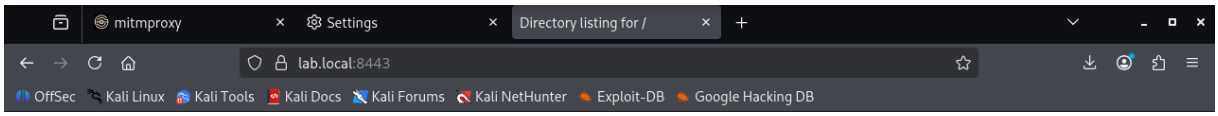


KARŞILAŞTIRMA

TLS SÜRÜMÜ	GÜÇLÜ SUNUCU	ZAYIF SUNUCU
TLS 1.0	Kapalı	Açık
TLS 1.1	Kapalı	Açık
TLS 1.2	Kapalı	Açık
TLS 1.3	Açık	Açıl

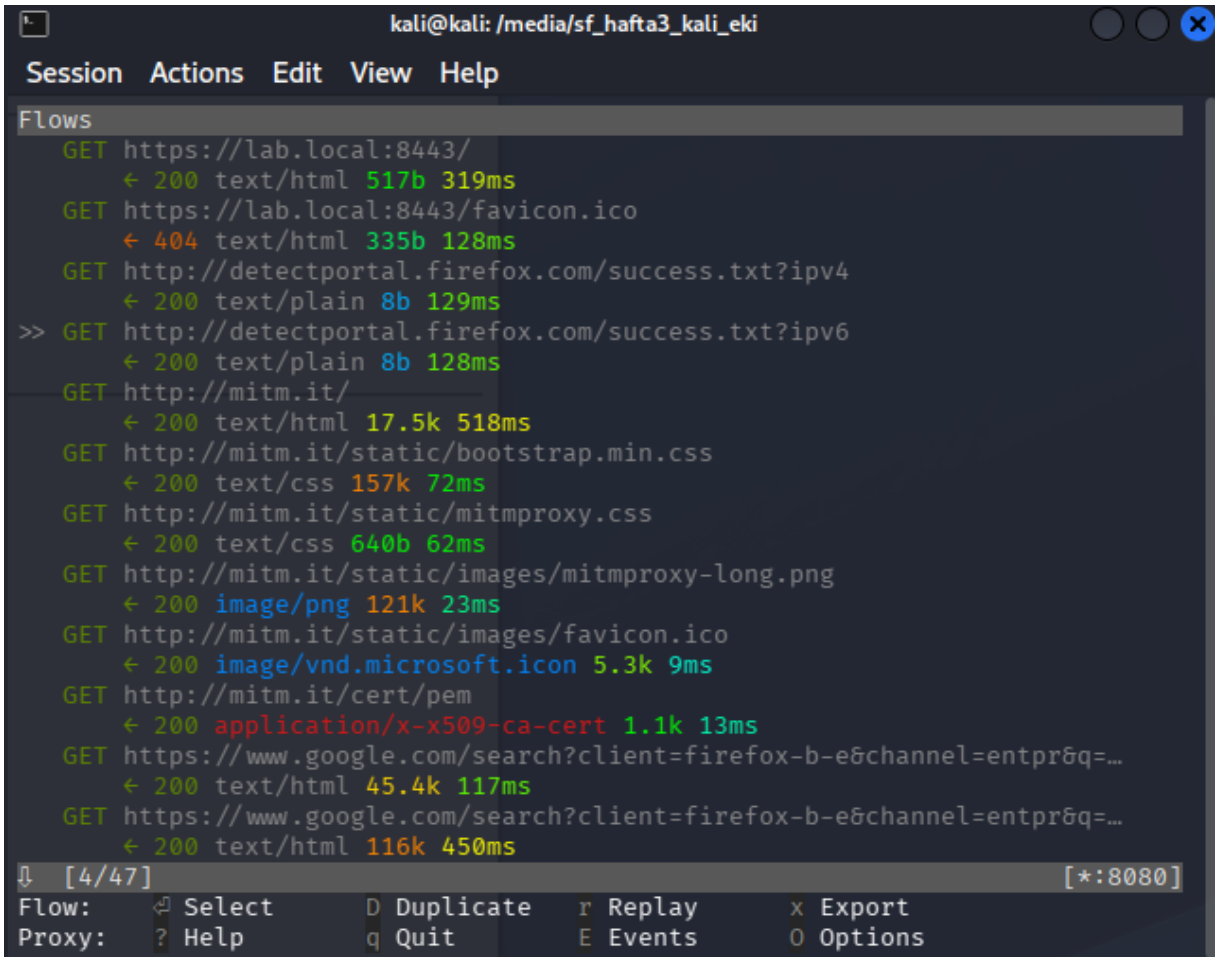

Kali Linux
Warning: Potential Securi
Not Secure
lab.local:8443
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
Warning: Potential Security Risk Ahead
Firefox detected a potential security threat and did not continue to lab.local. If you visit this site, attackers could try to steal information like your passwords, emails, or credit card details.
What can you do about it?
The issue is most likely with the website, and there is nothing you can do to resolve it.
If you are on a corporate network or using antivirus software, you can reach out to the support teams for assistance. You can also notify the website's administrator about the problem.
Learn more...
Go Back (Recommended)
Advanced...


Downloading Certificate
You have been asked to trust a new Certificate Authority (CA).
Do you want to trust "mitmproxy" for the following purposes?
Trust this CA to identify websites.
Trust this CA to identify email users.
Before trusting this CA for any purpose, you should examine its certificate and its policy and procedures (if available).
View
Examine CA certificate
Cancel
OK



Directory listing for /

- BENIOKU_KALI.md
- gorev1_pki_uret.py
- gorev2_https_sunucu.py
- pki/
- tarama_guclu.txt
- zayif_sunucu.py



Laboratuvar sonunda şunlar geri alındı: (1) Firefox proxy ayarı “No proxy” yapıldı, (2) mitmproxy’nin kök CA’sı Authorities listesinden silindi, (3) network.proxy.allow_hijacking_localhost tekrar false yapıldı. Tarayıcı güvenli duruma döndürüldü.

6.1 · Güçlü sunucu hangi TLS sürümünü ve şifre takımını tercih etti?

Güçlü sunucu yalnızca TLS 1.3'ü etkin tuttu ve tercih edilen şifre takımı TLS_AES_256_GCM_SHA384 (256 bit) oldu. Bu değerler, modern bir TLS 1.3 yapılandırmasında beklenen sonuçtur ve ana laboratuvardaki istemci çıktısıyla (TLS 1.3 üzerinden AES-256-GCM el sıkışması) uyumludur.

6.2 · Güçlü ve zayıf sunucu arasındaki fark neydi? Hangi sürümleri kapatırdınız?

Fark, kabul edilen TLS sürümleri ve şifre takımlarındaydı: güçlü sunucu yalnızca TLS 1.3 ve üç modern cipher sunarken, zayıf sunucu TLS 1.0/1.1/1.2'yi ve aralarında anonim (AECDH), 64 bit etiketli (CCM8) ve SHA-1 tabanlı eski takımların bulunduğu onlarca cipher’ı kabul etti. Bir sistem yöneticisi olsaydım TLS 1.0, 1.1 ve mümkünse 1.2'yi kapatıp yalnızca TLS 1.3 (gerekirse güçlü cipher’larla sınırlı TLS 1.2) bırakırdım; ayrıca anonim ve eski cipher takımlarını tamamen devre dışı bırakırdım. Sebep: eski sürüm ve zayıf cipher’lar downgrade ve MITM saldırılarına yüzey açar.

6.3 · Firefox neden önce uyardı, sonra uyarmadı? Bu, bir CA’ya güvenmeyi nasıl açıklar?

Önce uyardı çünkü mitmproxy’nin sunduğu sahte sertifikayı imzalayan kök CA, Firefox’un güvenilen CA listesinde yoktu; güven zinciri kurulamadığı için bağlantı reddedildi. mitmproxy CA’sını Authorities listesine ekleyip “web sitelerini tanımla” yetkisi verince güven zinciri tamamlandı ve Firefox sahte sertifikayı geçerli kabul etti, uyarı kalktı. Bu şunu gösterir: HTTPS güvenliği tamamen “hangi kök CA’lara güvendiğimiz” kararına dayanır. Güvenilen bir kök, onun imzaladığı her sertifikayı otomatik olarak geçerli kılar; dolayısıyla tek bir kötü/ele geçirilmiş CA, tüm güveni çökertebilir.

6.4 · Saldırganın neye sahip olması gerekiyordu? Gerçek bir sitede neden kolay değil?

Bu saldırının çalışması için saldırganın iki şeye sahip olması gerekiyordu: (1) kurbanın trafiğini kendi üzerinden geçirebilmesi (proxy), (2) kurbanın tarayıcısında güvenilen bir kök CA. Burada CA’yı kullanıcı kendi eliyle ekledi. Gerçek bir sitede (örneğin bir banka) saldırgan bunu kolayca yapamaz çünkü kurbanın cihazına güvenilir bir kök CA yerleştiremez; herkese güvenilen gerçek bir CA’yı ele geçirmek veya ona sahte sertifika imzalatmak son derece zordur. Ayrıca Sertifika Şeffaflığı (CT) tüm verilen sertifikaları herkese açık loglara yazar; sahte bir sertifika burada hemen fark edilir. CAA kayıtları ise bir alan adı için yalnızca belirli CA’ların sertifika verebilmesini sağlar. Bu mekanizmalar, tek bir CA’nın sessizce kötüye kullanılmasını pratikte çok güçleştirir.